

Data Protection Impact Assessment

Proactive Disclosures

Document Name	DPIA – Proactive disclosures
Author/Owner (name and job title)	Hannah Silk / Iman Elmehdawy
Department/Team	Information Access / Information Management Service
Document Status (draft, published or superseded)	Draft
Version Number	V0.1
Release Date	
Approver (if applicable)	
Review Date	
Distribution (internal or external)	Internal

Privacy by design at the ICO

Welcome to the data protection impact assessment process. You should use this every time you want to implement or change a product or process. It is essential to managing your own project risks but also to managing the corporate risks of the ICO.

Responsibilities

It is your responsibility to ensure that data protection impact is taken into account during the design and build of your product or service. To do this successfully, you will need to be able to explain what your proposal is, and map out how data is used. This includes, amongst other things, where data might sit at any time geographically, but also the purpose of its use at different points in time.

Remember the basics. Key to a good assessment is knowing at all points in the process: what data you are collecting/using, why, where it will be stored and for how long, who will access it and why, how it will be kept secure and whether it's being transferred to any other country.

Your Information Asset Owner (your Director) is ultimately responsible for managing any residual risk once you have completed any mitigations to the risks you identify.

The Information Management Service, working on behalf of our DPO, can help complete the paperwork, provide compliance advice and spot risks. It is not the Service's responsibility to own, manage or mitigate the risks identified during the process.

Getting advice

You might also need advice from subject matter experts in other teams to make sure that you understand how something works or risks to what you are proposing to do. This is particularly likely if it involves new, or changing, technologies. Getting this advice will help to provide your IAO with assurance that you have understood and identified the risks.

You might well be working on a contract or agreement and a Security Opinion Report at the same time – these are also ways that you can mitigate risks and should be viewed as part of the overall assessment process.

The paperwork

You should think of this as a live document. You might change your plans or new information might come to light that changes the risk profile of your proposal. If that's the case, you should revisit the paperwork and update it to reflect any changes. You might also need to inform your IAO of new or changed risks.

The process

You should allow time for this process in your project plans. Start early! How long it takes will depend on what you're proposing, and how well you can explain it and identify risks. It can take several weeks to get the right advice and risk assessment in place.

Step 1

- Complete DPIA screening assessment. If you conclude that you do not need to complete a DPIA then you must make a record of your decision.
- If you do need to complete a DPIA then start completing the paperwork and notify the IM Service. Depending on what you're doing, the DPIA might need to be reviewed by the DPIA forum. You need to ensure the paperwork is sufficiently detailed, accurate and thorough before the forum is able to review it. This particularly applies to your descriptions of the processing activities you are proposing and how any associated technology works alongside it.
-

Step 2

- The forum is likely to provide advice and recommendations. You should consider this advice. If you decide not to follow it, then you must document your reasons why. If you do follow it, then most actions will need to be completed before go live. For example, updating privacy information or refining access controls.
- The forum is able to escalate risks to our Data Protection Officer and/or Risk and Governance Board if it is not comfortable with the processing activity being suggested or wants sign-off on advice.

When you have completed the DPIA paperwork and any actions, accepting that you might need to revisit it, you should get sign-off from your IAO before your product or service goes live.

If there are residual risks that your IAO would like to discuss, they can contact dpo@ico.org.uk. That discussion can be escalated to our Data Protection Officer and/or Risk and Governance Board if required.

Guidance for completing this template

Complete this Data Protection Impact Assessment (DPIA) template if your 'Screening Assessment - do I need to carry out a DPIA?' indicates a high risk to individuals. If you are unsure whether you need to complete a DPIA use the [screening assessment](#) first to help you decide.

Aim to complete your DPIA as early as possible as the outcome of the assessment could affect the viability of your plans. In extreme cases, you will not be able to continue with your plans without changing them, or at all.

Guidance notes are included within the template to help you with its completion- just hover your mouse over any blue text for further information.

The [Information Management Service](#) is also available for further advice and support. Please keep in mind our [service standards](#) if you require advice.

1. Process/system overview

1.1 Ownership

Project Title:	Proactive Disclosures
Project Manager:	Hannah Silk
Information Asset Owner:	Louise Byers
Data controller(s)	ICO
Data processor(s)	N/A

1.2 [Describe your new service or process](#)

The ICO already proactively publishes casework information online. An assessment was done in 2016 and it was concluded that datasets of the complaints and the self-reported breaches ([insert link to old PIA](#)) should be published on the website.

In light of the change of legislation (DPA 18 and UK GDPR), we need to assess again the disclosure of personal data contained in the datasets.

We would like to publish casework datasets in order to fulfil our responsibilities under Article 57 (1)(d) of the UK GDPR and section 19 of the Freedom of Information Act. We also consider that publishing datasets will promote the understanding of data subjects of their rights in line with Article 57 (1) (b). These datasets may include personal data of sole traders and other non-

corporate entities. They may also contain criminal offences data if we opt to disclose cases of a criminal nature.

We will also be assessing the risk if we were to disclose other types of cases on ICE or cases on other systems (e.g. Crimson) as part of the casework datasets.

We have obtained [legal advice](#) in light of which we need to re-assess the risks of publishing certain types of cases and ways to mitigate those risks.

In order to ensure we are not in breach of section 132 of the Data Protection Act 2018 and the UK GDPR, and we are not breaching the legislation by publishing the names of sole traders in certain circumstances we will explore:

- Establishing a tick box for Case Officers in ICE so they can give a more informed assessment of whether the cases can be published
- Only publishing cases with specific outcomes
- Including standard wording in casework correspondence to notify DCs/PAs about proactive disclosures and give them a chance to opt out, a detailed risk assessment will be added.

1.3 [Personal data inventory - explain what personal data is involved](#)

Categories of data	Data subjects	Recipients	Overseas transfers	Retention period
Names of sole trader, as well as sector of work and potentially type of work (e.g. solicitor, doctor) and broad nature of complaint and outcome. This will be related to the person.	Sole traders and non-corporate entities who have been the subject of a complaint to the ICO	ICO Visitors to ICO website TNA digital services website	Yes – published online	2 years and then captured by TNA digital services

1.4 [Identify a lawful basis for your processing](#)

The lawful basis for processing is 6(1)(e) – public task

Criminal offence data may also be processed – a lawful basis for this will be added at a later date if it is decided that this information will be disclosed

1.5 [Explain why it is necessary to process this personal data](#)

Under section 19 of the Freedom of Information Act, the ICO is obliged to publish datasets (although this does not extend to personal data, e.g. sole traders).

Under Article 57(1)(d) of the UK GDPR the Commissioner has a responsibility to promote public awareness in relation to their rights and awareness of the data controllers in respect of their obligations under the UK GDPR. Publishing datasets online enables us to fulfil this obligation. This arguably extends to sole traders, who are considered data controllers and therefore accountable for processing personal data appropriately and in compliance with the law. We publish a [communicating our regulatory and enforcement activity policy](#) that explains our thinking and sets out the reasonable expectations.

Commented [BC1]: Detailed necessity test to be carried out at a later date

1.6 [Outline your approach to completing this DPIA](#)

The DPIA has been completed jointly by the Information Management and Information Access teams. This will be presented for review to the Risk and Governance Board (RGB) for review and sign off.

Legal advice has been sought in relation to our obligations under s132 of the Data Protection Act 2018, and whether it is appropriate for the Commissioner to rely in 6(1)(e) – public task as its lawful basis for processing. This can be found [here](#).

A consultation with internal stakeholders is also currently under-way and responses will be summarised for the purpose of the DPIA.

Commented [IEM2]: Hannah please link to consultation summary

2.0 Data flows

2.1 Provide a [systematic description of your processing](#), from the point that the data is first collected through to its destruction.

If your plans involve the use of new technology you should explain how this technology works and outline any 'privacy friendly' features that are available.

A large, empty rectangular box with a thin black border, intended for the user to provide a systematic description of their data processing activities as required by section 2.1.

3.0 [Key principles and requirements](#)

[Purpose & Transparency](#)

1. Will you need to update our [privacy notices](#)?

Yes ☒ No ☐

2. If you are not updating our privacy notices how do you intend to communicate information about your processing to the data subjects?

3. If [consent](#) is your lawful basis for processing personal data are you maintaining appropriate records of the data subjects consent?

Yes ☐ No ☐ N/a ☒

4. If legitimate interests is your lawful basis for processing have you completed a [legitimate interest assessment](#)?

Yes ☐ No ☐ N/a ☒

If applicable please provide a link to your completed assessment.

Accuracy

5. Are you satisfied the personal data you are processing is accurate?

Yes ☒ No ☐

6. How will you ensure the personal data remains accurate for the duration of your processing?

Data extracted from casework will be the most up to date version.

7. If the personal data isn't being obtained directly from the data subject what steps will you take to [verify accuracy](#)?

Commented [IEM3]: Need to confirm that only cases ran by sole traders will be published which means it is directly coming from DS

Minimisation, Retention & Deletion

8. Have you done everything you can to minimise the personal data you are processing?

Yes ☒ No ☐

9. How will you ensure the personal data are deleted at the end of the retention period?

Commented [IEM4]: If IA will coordinate the publication as usual they will have to ensure dataset are deleted at the end of the period

10. Will you need to update the [retention and disposal schedule](#)?

Yes ☐ No ☐

Integrity and confidentiality

11. Where will the personal data be [stored](#)?

12. Are there appropriate [access controls](#) to keep the personal data secure?

Yes ☒ No ☐

13. Have you contacted the [cyber security team](#) for a security assessment of your plans?

Yes ☐ No ☐ N/a ☐

If applicable please provide a link to any assessment.

14. Please explain the policies, training or other instructions you intend to put in place to enable staff to operate the new system or process securely.

Accountability

15. Who will be the [Information Asset Owner](#) for this personal data?

--

16. Will you need to update our [Article 30 record of processing activities](#)?

Yes ☐ No ☐

17. If you are using a data processor have you agreed, or will you be agreeing, a written contract with them?

Yes ☐ No ☐ N/a ☐

Individual Rights

18. Is there a means of providing the data subjects with [access](#) to the personal data being processed?

Yes ☐ No ☐

19. Can [inaccurate or incomplete](#) personal data be updated on receipt of a request from a data subject?

Yes ☐ No ☐

20. Can we [restrict](#) our processing of the personal data on receipt of a request from a data subject?

Yes ☐ No ☐

21. Can we [stop](#) our processing of the personal data on receipt of a request from a data subject?

Yes ☐ No ☐ N/a ☐

22. Can we [extract and transmit](#) the personal data in a structured, commonly used and machine readable format if requested by the data subject?

Yes ☐ No ☐ N/a ☐

23. Can we [erase](#) the personal data on receipt of a request from the data subject?

Yes ☐ No ☐

4.0 [Risk assessment](#)

Risk Description	Response to Risk	Risk Mitigation	Expected Risk Score		
			I	P	Total
			See Appendix 1 – Risk Assessment Criteria		
<i>Example:</i> Access controls are not implemented correctly and personal data is accessible to an unauthorised third party.	Reduce	<u>Existing mitigation:</u> We have checked that the system we intend to procure allows us to set access permissions for different users. <u>Expected mitigation:</u> We will appoint and train a system administrator who will be responsible for implementing access controls and monitoring access. The system administrator will also audit the system periodically to review access permissions.	3	2	6 - medium

5.0 Consult the DPO

Guidance: Submit your DPIA for consideration by the DPIA Forum. The process to follow is [here](#). Any recommendations from the DPOs team will be documented below and your DPIA will be returned to you. You should then record your response to each recommendation.

	<u>Recommendation</u>	Date and project stage	<u>Project Team Response</u>
1.			
2.			
2.			

6.0 Integrate the outcomes back into your plans

Guidance: Identify who is responsible for integrating the DPIA outcomes. The outcomes include any expected mitigation you need to take as identified in your risk assessment and any further actions resulting from the DPOs recommendations.

Action	Date for completion	Responsibility for Action	Completed Date

7.0 Expected residual risk and sign off

Guidance: Summarise the expected residual risk below. This is any remaining risk *after* you implement all of your mitigation measures and complete all actions.

It is never possible to remove all risk so this section shouldn't be omitted or blank. If the expected residual risk remains high (e.g. red on the traffic light scoring in the Appendix) then you will need to consult the ICO as the regulator by following the process used by external organisations.

7.1 [IAO sign off](#)

IAO (name and role)	Date	Project Stage

8.0 [Change history](#)

Guidance: To be completed by the person responsible for completing the DPIA and delivering the system, service or process)

Version	Date	Author	Change description
V0.1			First Draft

Appendix 1: Risk Assessment Criteria

The following criteria are aligned with our corporate risk assessment criteria.

Impact

Impact is the consequence of a risk to the rights and freedoms of individuals being realised. Factors to consider include the financial harm or emotional distress that can be expected to occur.

Impact	Scoring criteria
Very low (1)	No discernible impact on individuals.
Low (2)	Individuals may encounter a few minor inconveniences, which they will overcome without any problem (time spent re-entering information, annoyances, irritations, etc).
Medium (3)	Individuals may encounter significant inconveniences, which they will overcome despite a few difficulties (extra costs, denial of access to business services, fear, lack of understanding, stress, minor physical ailments, etc)
High (4)	Individuals may encounter significant consequences, which they should be able to overcome albeit with serious difficulties (misappropriation of funds, blacklisting by financial institutions, property damage, loss of employment, subpoena, worsening of health, etc).
Very high (5)	Individuals which may encounter significant, or even irreversible consequences, which they may not overcome (inability to work, long-term psychological or physical ailments, death, etc.).

Probability

Probability is the likelihood of a risk to the rights and freedoms of individuals being realised. Factors to consider include the expected frequency of occurrence, and the motivation and capability of threat sources (eg does the threat require insider knowledge and/or significant technical resources to exploit any vulnerability?).

Probability	Scoring criteria
Very low (1)	0-5% - extremely unlikely or improbable For example, the risk has not occurred before or is not expected to occur within the next three years.
Low (2)	6-20% - low but not improbable For example, the risk is expected to occur once a year.

Medium (3)	21-50% - fairly likely to occur For example, the risk is expected to occur several times a year.
High (4)	51-80% - more likely to occur than not For example, the risk is expected to occur once a month.
Very high (5)	81-100% - almost certainly will occur For example, the risk is expected to occur once a week.

Risk level

Risk level is a function of impact and probability, and is represented by a RAG rating.

Probability \ Impact	Very low (1)	Low (2)	Medium (3)	High (4)	Very high (5)
Very high (5)	Amber (5)	Amber (10)	Red (15)	Red (20)	Red (25)
High (4)	Green (4)	Amber (8)	Amber (12)	Red (16)	Red (20)
Medium (3)	Green (3)	Amber (6)	Amber (9)	Amber (12)	Red (15)
Low (2)	Green (2)	Green (4)	Amber (6)	Amber (8)	Amber (10)
Very low (1)	Green (1)	Green (2)	Green (3)	Green (4)	Amber (5)

Risk acceptance criteria

These criteria are guidelines only, and any risk treatment decisions should be made on a case-by-case basis. For example, it may be prudent to reduce a low risk because of legal and regulatory requirements.

Risk level	Acceptance criteria
Low (Green)	Within this range risks can be routinely accepted.
Medium (Amber)	Within this range risks can occasionally be accepted but shall be kept under regular review.
High (Red)	Within this range risks shall not be accepted and immediate action is required to reduce, avoid or transfer the risk.

Appendix 2: example risks to data subjects

Guidance: The following are examples of common risks associated with the processing of personal data to assist with your risk assessment. Not all of them will apply to your processing and the list is not exhaustive – you should consider specific risks that are relevant to your plans.

- Data is processed for unspecified / unlawful purposes/ not within expectations of data subjects
- Excessive data is processed
- Data is not kept up to date
- Data is kept for longer than is necessary by us
- Data is kept for longer than is necessary by data processor
- Data processed in contravention of data subject rights
- Data subjects unable to exercise their rights
- Data stolen or modified in transit
- Data stolen or modified at rest in our premises
- Data stolen or modified at rest in data processor premises
- Data transferred overseas to a jurisdiction that does not adequately protect data subject rights
- Re-identification of pseudonymised data by data processor or third party
- Unauthorised destruction or loss of data
- Data processor network / system / online portal not secure
- Data processor fails to process data in accordance with our instructions
- Personal data of children processed without appropriate safeguards / parental authority
- Consent of data subject not freely given (for example employer / employee processing)
- The data subject is particularly vulnerable (elderly or disabled) or is there a potential imbalance of power between the individual and the data controller (employee/employer)
- Source of data poses risks re accuracy (obtained from a unverified or old list)
- Risk to accuracy of data due to matching / combining data from different sources
- Use of new technology, e.g. fingerprinting, face recognition
- Monitoring or recording individuals
- Using profiling according to characteristics or behavior
- Non-compliance with DP principles

9.0 Template Change History (for Information Management Service only)

Version	Date	Author	Change description
v0.1	01/06/2020	Steven Johnston	First draft
v1.0	07/10/2020	Steven Johnston	First release
v1.1	07/01/2021	Iman Elmehdawy	Amendment to guidance note page 2.
v.1.2	18/03/2021	Helen Ward	Addition of Privacy by design at the ICO (pages 2 and 3)